

Scenario 3 output 1 ollama

After analyzing the provided system architecture, I've identified potential threats related to each of the requested threat categories. Please note that this is a comprehensive analysis, and the severity and likelihood may vary based on specific implementation details.

****1. Account Takeover****

```
* **Threat ID:** AT-001
* **Threat name:** Brute Force Attack on User Authentication
* **STRIDE category:** Privilege Escalation
* **Affected component/data flow:** EE1, P1, DS1
* **Attack scenario:** An attacker attempts to guess or crack user
passwords.
* **Impact:** Unauthorized access to user accounts.
* **Severity:** High
* **Likelihood:** Medium
* **Mitigation:** Implement rate limiting on login attempts, use strong
password hashing, and consider additional authentication factors (e.g.,
2FA).
* **OWASP LLM Top 10 mapping:** A5:2019-Insecure Authentication
```

****2. Recovery Token Abuse****

```
* **Threat ID:** RT-001
* **Threat name:** Recovery Token Misuse
* **STRIDE category:** Privilege Escalation
* **Affected component/data flow:** P2, DS2
* **Attack scenario:** An attacker obtains a recovery token and uses it
to
access or modify user accounts.
* **Impact:** Unauthorized access or modification of user accounts.
* **Severity:** High
* **Likelihood:** Low (due to restricted token lifecycle)
* **Mitigation:** Implement secure token generation, validation, and
storage mechanisms (e.g., DS2).
* **OWASP LLM Top 10 mapping:** A9:2017-Insufficient Logging &
Monitoring
```

****3. Token Replay****

```
* **Threat ID:** TR-001
* **Threat name:** Recovery Token Replay Attack
* **STRIDE category:** Session Management
* **Affected component/data flow:** P2, DS2, EE1
* **Attack scenario:** An attacker intercepts and replays a recovery
token.
* **Impact:** Unauthorized access to user accounts.
* **Severity:** High
* **Likelihood:** Low (due to secure token validation mechanisms)
* **Mitigation:** Implement secure token validation, lifetime
management,
and revocation mechanisms.
```

* **OWASP LLM Top 10 mapping:** A7:2017–Cross–Site Request Forgery (CSRF)

4. Token Leakage

* **Threat ID:** TL–001
* **Threat name:** Recovery Token Exposure
* **STRIDE category:** Data Protection
* **Affected component/data flow:** P2, DS2
* **Attack scenario:** A recovery token is exposed or leaked.
* **Impact:** Unauthorized access to user accounts.
* **Severity:** High
* **Likelihood:** Low (due to secure storage and transmission mechanisms)
* **Mitigation:** Implement secure token storage, transmission, and handling practices.
* **OWASP LLM Top 10 mapping:** A3:2017–Sensitive Data Exposure

5. Identity Verification Bypass

* **Threat ID:** IVB–001
* **Threat name:** Bypassing Recovery Authorization
* **STRIDE category:** Authentication
* **Affected component/data flow:** P2, DS1
* **Attack scenario:** An attacker bypasses or manipulates the recovery authorization process.
* **Impact:** Unauthorized access to user accounts.
* **Severity:** High
* **Likelihood:** Low (due to secure authentication mechanisms)
* **Mitigation:** Implement secure identity verification and recovery authorization practices.
* **OWASP LLM Top 10 mapping:** A1:2017–Injection

6. Privilege Escalation

* **Threat ID:** PE–001
* **Threat name:** Unauthorized Account Access or Modification
* **STRIDE category:** Privilege Escalation
* **Affected component/data flow:** P3, DS1
* **Attack scenario:** An attacker gains unauthorized access to user accounts or modifies account information.
* **Impact:** Unauthorized access or modification of user accounts.
* **Severity:** High
* **Likelihood:** Medium
* **Mitigation:** Implement secure authentication and authorization mechanisms for profile management (P3).
* **OWASP LLM Top 10 mapping:** A6:2017–Cross–Site Scripting (XSS)

7. Unauthorized Profile Modification

* **Threat ID:** UPM–001
* **Threat name:** Unauthenticated Account Information Update
* **STRIDE category:** Data Manipulation
* **Affected component/data flow:** P3, DS1
* **Attack scenario:** An attacker modifies user account information without proper authorization.

- * **Impact:** Unauthorized modification of user accounts.
- * **Severity:** High
- * **Likelihood:** Medium
- * **Mitigation:** Implement secure authentication and authorization mechanisms for profile management (P3).
- * **OWASP LLM Top 10 mapping:** A6:2017–Cross–Site Scripting (XSS)

8. Prompt Injection

- * **Threat ID:** PI-001
- * **Threat name:** External LLM Input Manipulation
- * **STRIDE category:** Data Validation
- * **Affected component/data flow:** P5, EE2
- * **Attack scenario:** An attacker injects malicious prompts into the external LLM.
- * **Impact:** Unintended behavior or security vulnerabilities in the LLM output.
- * **Severity:** Medium
- * **Likelihood:** Low (due to sanitized prompt creation)
- * **Mitigation:** Implement secure prompt sanitization and validation mechanisms for P5.
- * **OWASP LLM Top 10 mapping:** A1:2017–Injection

9. Sensitive Information Disclosure

- * **Threat ID:** SID-001
- * **Threat name:** Unintended Exposure of Recovery Tokens or Account Data
- * **STRIDE category:** Data Protection
- * **Affected component/data flow:** P2, DS2, EE1
- * **Attack scenario:** An attacker exposes or leaks recovery tokens or sensitive account data.
- * **Impact:** Unauthorized access to user accounts.
- * **Severity:** High
- * **Likelihood:** Low (due to secure storage and transmission mechanisms)
- * **Mitigation:** Implement secure token storage, transmission, and handling practices for P2 and DS2.
- * **OWASP LLM Top 10 mapping:** A3:2017–Sensitive Data Exposure

10. Insecure Output Handling

- * **Threat ID:** IOH-001
- * **Threat name:** Unvalidated or Malicious External LLM Output
- * **STRIDE category:** Data Validation
- * **Affected component/data flow:** P5, EE2
- * **Attack scenario:** An attacker injects malicious output from the external LLM.
- * **Impact:** Unintended behavior or security vulnerabilities in the system.
- * **Severity:** Medium
- * **Likelihood:** Low (due to sanitized prompt creation)
- * **Mitigation:** Implement secure output validation and handling mechanisms for P5.
- * **OWASP LLM Top 10 mapping:** A1:2017–Injection

****11. Excessive AI Agency****

* **Threat ID:** EAA-001
* **Threat name:** Unintended Behavior or Influence due to External LLM Output
* **STRIDE category:** Data Manipulation
* **Affected component/data flow:** P4, EE2
* **Attack scenario:** An attacker exploits the external LLM's influence on user decisions.
* **Impact:** Unintended behavior or security vulnerabilities in the system.
* **Severity:** Medium
* **Likelihood:** Low (due to guidance-only AI assistant)
* **Mitigation:** Implement secure AI output handling and validation mechanisms for P4.
* **OWASP LLM Top 10 mapping:** A2:2017-Broken Access Control

****12. External LLM Risks****

* **Threat ID:** ELLR-001
* **Threat name:** Unintended Behavior or Security Vulnerabilities due to External LLM Provider
* **STRIDE category:** Data Manipulation
* **Affected component/data flow:** EE2, P5
* **Attack scenario:** An attacker exploits the external LLM provider's security vulnerabilities.
* **Impact:** Unintended behavior or security vulnerabilities in the system.
* **Severity:** Medium
* **Likelihood:** Low (due to secure communication and input validation mechanisms)
* **Mitigation:** Implement secure communication and input validation mechanisms for P5 and EE2.
* **OWASP LLM Top 10 mapping:** A1:2017-Injection